

HIPAA Security Audit Report - Acme System

Organization Name: Acme Health Systems

Application Assessed: Acme System

Auditor: SecureComply, Inc.

Audit Period: July 10-17, 2025

Report Date: July 19, 2025

Report Version: 1.0

Table of Contents

1. [Executive Summary](#)
 2. [Scope of Audit](#)
 3. [Assessment Methodology](#)
 4. [Compliance Summary](#)
 5. [Detailed Control Review](#)
 6. [Findings & Recommendations](#)
 7. [Conclusion](#)
 8. [Appendices](#)
 9. [Annex A: Sample Risk Assessment Summary](#)
 10. [Annex B: Training Log \(Extract\)](#)
 11. [Annex C: Sample Business Associate Agreement](#)
 12. [Annex D: Sample Audit Logs](#)
-

1. Executive Summary

This HIPAA audit reviewed the administrative, physical, and technical safeguards implemented for **Acme System**, a cloud-native SaaS healthcare solution. The audit found Acme Health Systems to be **compliant across all required HIPAA safeguards**, with only one minor procedural gap in employee training tracking.

2. Scope of Audit

In-Scope Components

- Acme System application backend/frontend
- AWS infrastructure (EC2, S3, RDS, IAM)
- Identity & Access Management (Okta, VPN)
- Developer access control and GitHub repos
- Corporate policies, procedures, and training

Out of Scope

- Third-party BAA infrastructure
- Client devices (BYOD not enforced)

3. Assessment Methodology

- Interviews with IT, security, and compliance leads
- Documentation and policy reviews
- Infrastructure and application configuration checks
- Sample audit log reviews
- Control mapping to HIPAA 45 CFR Part 164 Subpart C

Tools used: AWS Config, AWS CloudTrail, Okta Admin Console, Burp Suite, Nessus, internal compliance scripts

4. Compliance Summary

Category		Controls		Compliant		Partial		Non-Compliant			
										Administrative	
1		0		Physical		4		4		0	
										Technical	
										5	
										0	
										Organizational	
										2	
										Total	
										22	
										21	
										1	
										0	

5. Detailed Control Review

Administrative Safeguards (164.308)

Control Requirement		Status	Notes
			Risk Analysis (a)(1)(ii)(A)
Compliant			Risk assessment updated May 2025. See Annex A.
Management (a)(1)(ii)(B)		Compliant	Risks mitigated with action items tracked in Jira.
Sanction Policy (a)(1)(ii)(C)		Compliant	Policy enforced with HR and IT coordination.
Workforce Security (a)(3)		Compliant	Termination access reviews within 24 hours.
Information Access Management (a)(4)		Compliant	Okta policies enforce RBAC and Just-in-Time access.
Security Awareness and Training (a)(5)		△ Partial	Training occurs but refresher logs incomplete. See Annex B.
Security Incident Procedures (a)(6)		Compliant	IRP tested with live drill in Q2 2025.
Contingency Plan (a)(7)		Compliant	Disaster recovery tested via backup restore in staging.
Evaluation (a)(8)		Compliant	Internal HIPAA assessments done twice/year.
BA Contracts (b)(1)		Compliant	See example in Annex C.
Data Minimization (b)(2)		Compliant	Only minimum PHI required is collected.

Physical Safeguards (164.310)

Control Requirement	Status	Notes
Facility Access Control	Compliant	AWS hosts all infrastructure (SOC 2, ISO 27001).
Workstation Use	Compliant	MDM and VPN mandatory for remote access.
Device and Media Controls	Compliant	Asset disposal policy enforced by IT.
Physical Access Logs	Compliant	Managed by AWS physical security (see SOC 2 report).

Technical Safeguards (164.312)

Control Requirement	Status	Notes
Access Control	Compliant	Okta SSO + Duo MFA enforced.
Audit Controls	Compliant	CloudTrail, App logs retained 1 year. See Annex D.
Integrity Controls	Compliant	S3 versioning, DB checksum validation scripts.
Authentication	Compliant	OAuth2 + JWT tokens, session expiration in 30 min.
Transmission Security	Compliant	TLS 1.2+ with HSTS, data encryption in transit.

Organizational Requirements (164.314)

Control Requirement	Status	Notes
Business Associate Contracts	Compliant	All vendors reviewed for HIPAA BAAs.
Group Health Plans	Compliant	Not applicable to Acme System use case.

6. Findings & Recommendations

Finding 1: Lack of Complete Refresher Training Logs

- **Control Reference:** 164.308(a)(5)
- **Risk Level:** Low
- **Description:** While all employees receive onboarding HIPAA training, annual refresher training records are inconsistently logged.
- **Recommendation:** Implement a Learning Management System (LMS) or automated tracking for annual training.
- **Target Date:** September 30, 2025
- **Responsible Party:** Compliance and HR

7. Conclusion

Acme System has implemented strong HIPAA-aligned security controls across its cloud platform and organizational structure. Only a minor procedural improvement is recommended. No technical or operational non-compliance risks were found.

Final Assessment: HIPAA Compliant with one low-priority action

8. Appendices

Appendix A: Documents Reviewed

- HIPAA Risk Assessment Report (2025)
- Security Awareness Training Policy
- Incident Response Plan v2.3
- Business Associate Agreements
- Device Management and Disposal Policy
- Access Control Policy
- Encryption Policy
- Disaster Recovery Plan

Appendix B: Systems and Tools Assessed

- AWS (IAM, CloudTrail, EC2, S3, RDS)
 - Okta (SSO, MFA, access groups)
 - GitHub Enterprise (repos, branch protections)
 - Slack Enterprise Grid (audit logs)
 - Google Workspace Admin Console
 - Vanta (policy and audit dashboard)
-

Annex A: Sample Risk Assessment Summary

Date of Assessment: 2025-05-18

Risks Identified:

- S3 bucket misconfiguration (resolved) - Excessive GitHub access (resolved via automation)

Remediated:

Next Scheduled Review: November 2025

Annex B: Training Log (Extract)

Employee	Role	Training Date	Refresher Due	Notes
Alice Wong	DevOps Engineer	2025-01-15	2026-01-15	
Marcus Green	Backend Developer	2024-12-20	OVERDUE	Refresher not recorded
Sarah Khan	Compliance Lead	2025-02-01	2026-02-01	

Annex C: Sample Business Associate Agreement

Vendor: HealthMetrics Inc.
Agreement Date: 2024-11-01
Key Clauses: - Data encryption at rest and in transit - 48-hour breach notification - Limited PHI access by vendor - Termination clause with 30-day notice
Status: Signed and archived

Annex D: Sample Audit Logs

Source: AWS CloudTrail (Redacted Sample)

```
json { "eventTime": "2025-07-10T15:10:44Z", "eventName":  
"ConsoleLogin", "userIdentity": { "userName": "alice.wong" },  
"sourceIPAddress": "192.168.23.10", "responseElements":  
{ "ConsoleLogin": "Success" } }
```

makefile **Source**: Acme System App Logs 2025-07-11T08:45:22Z |
UserID: 83921 | Action: Viewed patient record | PatientID: 29913
2025-07-11T09:00:11Z | UserID: 83921 | Action: Exported patient
report | PatientID: 29913

End of Report